Individual Reflection Report on Usability and Security Considerations

Course Code & Name: INTE2675 / 2650 Human-Centered Security

Student Name: Anthony Mackenzi Fernando

Student ID: S4129857

Group Number: 6

1. Critical Reflection on Design Decisions

Specific RBA Notification Design Decision: Matching User Effort and Restrictions to Risk Tier

In our Risk-Based Authentication (RBA) notification system, a fundamental design decision was establishing how user recovery effort and account restrictions should scale across system risk tiers. In template set v1.0, required protective actions were directly tied to the risk score: Medium alerts demanded minimal friction (on-screen number matching); High alerts enforced targeted functional restrictions blocking password changes, financial data access, and MFA configuration until a guided flow was completed; and Critical alerts triggered immediate account lockout requiring a multi-step recovery process (nearly 5 minutes) or Service Desk escalation.

Balancing Usability and Security

This architecture attempted to balance rapid threat containment against user productivity. From a strict security standpoint, restricting sensitive administrative capabilities (such as financial approvals or credential modifications) upon detecting anomaly signals immediately limits lateral attacker movement. However, from a usability perspective, enforcing high-effort protective tasks creates operational friction, particularly when triggered by false positives or benign user behavior (e.g: shift workers logging in during non-standard hours or colleagues mistyping credentials on shared workstations).

Tensions, Trade-offs, and Design Compromises

Applying Protection Motivation Theory (PMT) response-cost concepts exposed severe practical trade-offs:

- **Account Restriction vs. Workplace Continuity:** In manager and regular staff scenarios, restricting access to core account capabilities directly disrupted daily workflows. During my think-aloud evaluation with a registered healthcare professional working on shared hospital computers, the participant expressed frustration over lost financial access,

emphasizing that notifications must explicitly detail what functions remain operational rather than leaving access status ambiguous.

- **Response Cost vs. Security Postponement:** In scenarios involving repeated failed sign in attempts, the system restricted the account and required a password reset. Because the notification clearly indicated that no one had gained access, the study participant judged the forced recovery effort unreasonable during an active shift, noting that under time pressure they would put off the task until the end of their shift. This demonstrated that when perceived severity is low, high response cost leads users to intentionally postpone security tasks, leaving accounts in a restricted or vulnerable state for hours.
- **Transparency vs. Anxiety:** Transparently communicating negative consequences (e.g: warning that the account would be locked if a check failed) was intended to promote caution. In practice, warning users about lockout induced anxiety, reducing self-efficacy and making users fearful of mistyping verification codes.

How This Changed My Understanding of Security Features

This experience fundamentally reshaped my understanding of human-centered security design. A protective security control that users actively defer until the end of a work shift fails its primary security objective. Protective friction must not scale solely based on backend risk scores; it must dynamically adjust to the user's operational realities and task constraints.

2. Learning from User Evaluation

Engaging with Users and Human Behavior Insights

Directly conducting the think-aloud evaluation provided deep insight into how operational environments govern security interactions. The participant’s routine logging into shared computers up to 30 times a shift illustrated how extreme time scarcity dictates user decision-making.

Key Evaluation Insights

- **Operational Time Scarcity Drives Habituation:** Users operating under high workload conditions employ drastic mental heuristics. Tasks perceived as taking "only 5 minutes" are viewed as major interruptions during active shifts. Consequently, routine security warnings are habitually dismissed unless an explicit breach indicator is presented.
- **Value of Explicit Time Cues:** Incorporating clear time estimates (e.g: "about 5 minutes″) in Critical notifications successfully managed user expectations and restored self-efficacy.

The participant noted that extending explicit time estimates to High-tier notifications would significantly reduce user reluctance to complete forced security flows.

- **Non-Binary Account Perception:** Users do not view their system access as a simple binary state (locked vs. unlocked). They require explicit confirmation of granular permissions during restriction periods to maintain workplace continuity.

3. Future Application of Learning

Informing Future Design Decisions

My future design practice in human-centered security will incorporate three core principles:

1. **Context-Aware Dynamic Response Costs:** I will implement adaptive recovery pathways that account for user operational states such as providing temporary "degraded access modes" for active shift workers to prevent complete task abandonment.
2. **Transparent Permission Granularity:** Security restriction notices will explicitly list both restricted and permitted capabilities (e.g: “Restricted: Financial Approvals. Permitted: General Email & Rostering") to prevent unnecessary workflow paralysis.
3. **Integrated Time-to-Complete Cues:** I will mandate concise time expectations across all security alerts to bolster user self-efficacy and eliminate hesitation caused by unknown effort requirements.

Conclusion

Through this project, I gained a deeper appreciation of the fundamental interdependence between technical security enforcement and human usability. While account restrictions and automated controls can be technically robust, their practical efficacy ultimately depends on whether end users can accurately interpret notifications and execute required actions within the constraints of their daily operational environments.

Directly evaluating user responses particularly through my think-aloud session with a healthcare professional demonstrated how operational time pressure, ambiguity surrounding compromise status, and fear of workflow disruption shape user interactions with security alerts. I learned that human-centered security design must provide absolute clarity by explicitly communicating breach status, outlining precise user action items, offering realistic completion time estimates, and detailing which system capabilities remain available during restriction periods.

Moving forward into future engineering and design practices, I will evaluate technical security controls through both systemic and human centric lenses. My goal will be to develop security architectures that maintain strong protective boundaries while empowering users to respond with confidence and sustain essential work safely.